

CIS Critical Security Controls®

Version 8.1

March 2025

Acknowledgments

CIS would like to thank the many security experts who volunteer their time and talent to support the CIS Critical Security Controls® (CIS Controls®) and other CIS work. CIS products represent the effort of a veritable army of volunteers from across the industry, generously giving their time and talent in the name of a more secure online experience for everyone.

Creative Commons License

This work is licensed under a Creative Commons Attribution-NonCommercial-No Derivatives 4.0 International Public License (the link can be found at <https://creativecommons.org/licenses/by-nc-nd/4.0/legalcode>).

To further clarify the Creative Commons license related to the CIS Controls® content, you are authorized to copy and redistribute the content as a framework for use by you, within your organization and outside of your organization, for non-commercial purposes only, provided that (i) appropriate credit is given to CIS, and (ii) a link to the license is provided. Additionally, if you remix, transform, or build upon the CIS Controls, you may not distribute the modified materials. Users of the CIS Controls framework are also required to refer to (<http://www.cisecurity.org/controls/>) when referring to the CIS Controls in order to ensure that users are employing the most up-to-date guidance. Commercial use of the CIS Controls is subject to the prior approval of the Center for Internet Security, Inc. (CIS®).

March 2024

Contents

Overview

Introduction	1
Evolution of the CIS Controls	1
This Version of the CIS Controls	3
The CIS Controls Ecosystem (“It’s not about the list”)	4
How to Get Started	5
Asset Classes	8

CIS Critical Security Controls

Control 1: Inventory and Control of Enterprise Assets	14
Why is this Control critical?	14
Procedures and tools	15
Safeguards	16
Control 2: Inventory and Control of Software Assets	18
Why is this Control critical?	18
Procedures and tools	19
Safeguards	20
Control 3: Data Protection	22
Why is this Control critical?	22
Procedures and tools	23
Safeguards	24
Control 4: Secure Configuration of Enterprise Assets and Software	27
Why is this Control critical?	27
Procedures and tools	28
Safeguards	29

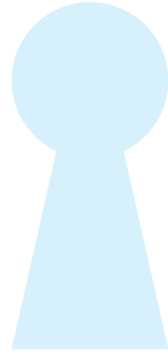
Control 5: Account Management	32
Why is this Control critical?	32
Procedures and tools	32
Safeguards	33
Control 6: Access Control Management	35
Why is this Control critical?	35
Procedures and tools	36
Safeguards	37
Control 7: Continuous Vulnerability Management	39
Why is this Control critical?	39
Procedures and tools	40
Safeguards	41
Control 8: Audit Log Management	43
Why is this Control critical?	43
Procedures and tools	43
Safeguards	44
Control 9: Email and Web Browser Protections	47
Why is this Control critical?	47
Procedures and tools	47
Safeguards	49
Control 10: Malware Defenses	51
Why is this Control critical?	51
Procedures and tools	51
Safeguards	52
Control 11: Data Recovery	54
Why is this Control critical?	54
Procedures and tools	55
Safeguards	55
Control 12: Network Infrastructure Management	57
Why is this Control critical?	57
Procedures and tools	58
Safeguards	58
Control 13: Network Monitoring and Defense	61
Why is this Control critical?	61
Procedures and tools	62
Safeguards	62

Control 14: Security Awareness and Skills Training	65
Why is this Control critical?	65
Procedures and tools	66
Safeguards	67
Control 15: Service Provider Management	70
Why is this Control critical?	70
Procedures and tools	71
Safeguards	72
Control 16: Application Software Security	74
Why is this Control critical?	74
Procedures and tools	75
Safeguards	78
Control 17: Incident Response Management	82
Why is this Control critical?	82
Procedures and tools	83
Safeguards	83
Control 18: Penetration Testing	86
Why is this Control critical?	86
Procedures and tools	87
Safeguards	88

Appendix

Acronyms and Abbreviations	A1
Change Log	A3
Glossary	A4
Resources and References	A9
Controls and Safeguards Index	A13

Overview



Introduction

The CIS Critical Security Controls® (CIS Controls®) started as a simple grassroots activity to identify the most common and important real-world cyber attacks that affect enterprises every day, translate that knowledge and experience into positive, constructive action for defenders, and then share that information with a wider audience. The original goals were modest—to help people and enterprises focus their attention and get started on the most important steps to defend themselves from the attacks that really mattered.

Led by the Center for Internet Security® (CIS®), the CIS Controls have matured into an international community of volunteer individuals and institutions that:

- Share insights into attacks and attackers, identify root causes, and translate that into classes of defensive action
- Create and share tools, working aids, and stories of adoption and problem-solving
- Map the CIS Controls to regulatory and compliance frameworks in order to ensure alignment and bring collective priority and focus to them
- Identify common problems and barriers (like initial assessment and implementation roadmaps), and solve them as a community

The CIS Controls reflect the combined knowledge of experts from every part of the ecosystem (companies, governments, individuals), with every role (threat responders and analysts, technologists, information technology (IT) operators and defenders, vulnerability-finders, tool makers, solution providers, users, policy-makers, auditors, etc.), and across many sectors (government, power, defense, finance, transportation, academia, consulting, security, IT, etc.), who have banded together to create, adopt, and support the CIS Controls.

Evolution of the CIS Controls

The CIS Controls started like many similar activities; we gathered experts together, and shared and argued until we reached an agreement. This can be very valuable, depending on the people at the table and their experience. Through documenting and sharing the output, all enterprises can benefit from the work of people they cannot hire or even meet. You can improve the outcome (and your confidence in it) through selecting experts that represent a wide range of knowledge, bringing consistency to the process, and ensuring use of the best-available information (especially about attacks). In the end, you are still depending on the good judgment of a relatively small group of people, captured in an informal and narrative way.

At CIS, we have been on a multi-year path to bring more data, rigor, and transparency to the process of best practice recommendations (the CIS Benchmarks® and the CIS Controls). All of these elements are essential to the maturation of a science to underlie cyber defense; and, all are necessary to allow the tailoring and “negotiation” of security actions applicable in specific cases, and as required through specific security frameworks, regulations, and similar oversight schemes.

In the earliest versions of the CIS Controls, we used a standard list of publicly known attacks as a simple and informal test of the usefulness of specific recommendations. Starting in 2013, we worked with the Verizon Data Breach Investigations Report (DBIR) team to map the results of their large-scale data analysis directly to the CIS Controls, as a way to match their summaries of attacks into a standard program for defensive improvement.

CIS has recently released the **Community Defense Model (CDM)**, which is our most data-driven approach so far. In its initial version, the CDM looks at the conclusions from the most recent Verizon DBIR, along with data from the **Multi-State Information Sharing and Analysis Center® (MS-ISAC®)**, to identify what we believe to be the five most important types of attacks. We describe those attacks using the **MITRE Adversarial Tactics, Techniques, and Common Knowledge® (MITRE ATT&CK®) Framework** in order to create attack patterns (or specific combinations of Tactics and Techniques used in those attacks). This allows us to analyze the value of individual defensive actions (i.e., Safeguards¹) against those attacks. Specifically, it also provides a consistent and explainable way to look at the security value of a given set of defensive actions across the attacker’s life cycle, and provide a basis for strategies like defense-in-depth. The details of this analysis are available on the CIS website. The bottom line is that we have taken a major step toward identifying the security value of the CIS Controls, or any subset of them. While these ideas are still evolving, at CIS we are committed to the idea of security recommendations based on data, presented transparently. For additional information, reference <https://www.cisecurity.org/controls/v8-1/>.

These activities ensure that the CIS Security Best Practices (which include the CIS Controls and CIS Benchmarks) are more than a checklist of “good things to do,” or “things that *could* help”; instead, they are a prescriptive, prioritized, highly focused set of actions that have a community support network to make them implementable, usable, scalable, and in alignment with all industry or government security requirements.

¹ “Safeguards” were known as “Sub-Controls” prior to Version 8 of the CIS Controls.

This Version of the CIS Controls

CIS Controls version 8.1 (v8.1) is an iterative update to version 8.0. As part of our process to evolve the CIS Controls, we establish “design principles” that guide us through any minor or major updates to the document. Our design principles for this revision are context, clarity, and consistency. Context enhances the scope and practical applicability of Safeguards by incorporating specific examples and additional explanations. Coexistence aligns with other major security frameworks to the extent practical, while preserving the unique features of the CIS Controls. Consistency maintains continuity for existing CIS Controls users, ensuring little to no change due to this update. Here are the broad changes we’ve made for each design principle:

■ Context

- We’ve updated the CIS Controls with new asset classes to better match the specific parts of an enterprise’s infrastructure each Safeguard applies to. New classes require new definitions, so we’ve also enhanced the descriptions of several Safeguards for greater detail, practicality, and clarity.

■ Coexistence

- The CIS Controls has always maintained alignment with evolving industry standards and frameworks and will continue to do so. This assists all users of the Controls and is a core principle of how the Controls operate. The release of NIST’s CSF 2.0 necessitated updated mappings and updated security functions.

■ Consistency

- Traditionally any iterative update to the CIS Controls should minimize disruption to Controls users. This means that no Implementation Groups were modified in this update, and the spirit of any given Safeguard remains the same. Additionally, the new asset classes and definitions needed to be consistently applied throughout the Controls, and in doing so some minor updates were added.

With these principles in mind, we’ve scoped the CIS Controls v8.1 to the following updates:

- Realigned NIST CSF security function mappings to match NIST CSF 2.0
- Included new and expanded glossary definitions for reserved words used throughout the Controls (e.g., plan, process, sensitive data)
- Revised asset classes, alongside new mappings to Safeguards
- Fixed minor typos in Safeguard descriptions
- Added clarification to a few anemic Safeguard descriptions

One key improvement to CIS Controls v8.1 mapping is the addition of the “Governance” security function. Effective governance provides the structure needed to steer a cybersecurity program toward achieving their enterprise goals. The Controls were designed to be comprehensive enough to protect and defend cybersecurity programs for any size enterprise, while being prescriptive enough to ease implementation. With the update to CIS Controls v8.1, governance topics are now specifically identified as recommendations that can be implemented to enhance the governance of a cybersecurity program. This will help our adopters better identify the governing pieces of the program as well as equip them with the evidence needed to demonstrate compliance.

The CIS Controls aim to streamline the process of designing, implementing, measuring, and managing enterprise security. This involves simplifying language to reduce duplication, focusing on measurable actions with defined metrics, and ensuring each Safeguard is clear and concise. CIS continues to balance the need to address current cybersecurity challenges with maintaining a stable, foundational cyber defense strategy, steering clear of overly complex or inaccessible technologies. Technology is constantly shifting, and the CIS Controls team is aware of the developments in artificial Intelligence, augmented reality, and ambient computing working to reshape our enterprise infrastructure in subtle and radical ways. We’re keeping both eyes open and already working on ideas for version 9 of the CIS Controls.

The CIS Controls Ecosystem (“It’s not about the list”)

Whether you use the CIS Controls, and/or another way to guide your security improvement program, you should recognize that “it’s not about the list.” You can get a credible list of security recommendations from many sources—it is best to think of the list as a starting point. It is important to look for the ecosystem that grows up around the list. Where can I get training, complementary information, explanations; how have others implemented and used these recommendations; is there a marketplace of vendor tools and services to choose from; how will I measure progress or maturity; how does this align with the myriad regulatory and compliance frameworks that apply to me? The true power of the CIS Controls is not about creating the best list, it is about harnessing the experience of a community of individuals and enterprises to actually make security improvements through the sharing of ideas, tools, lessons, and collective action.

To support this, CIS acts as a catalyst and clearinghouse to help us all learn from each other. Since Version 6, there has been an explosion of complementary information, products, and services available from CIS, and from the industry-at-large. Please email controlsinfo@cisecurity.org for the following kinds of working aids and other support materials:

- Mappings from the CIS Controls to a very wide variety for formal Risk Management Frameworks (like NIST®, Federal Information Security Modernization Act (FISMA), International Organization for Standardization (ISO), etc.)
- Use cases of enterprise adoption